

CYROPAY LTD

Information Security Posture — CISO Briefing

May 2026 | ISO/IEC 27001:2022 Gap Assessment Results | Classification: Confidential

93 Controls Assessed	27% Compliance Rate	1 Critical Risk	4 High Risks	10 Policies Live
----------------------	---------------------	-----------------	--------------	------------------

1. Executive Summary

CyroPay's ISO/IEC 27001:2022 gap assessment has identified a current overall compliance rate of 27% across all 93 Annex A controls. While CyroPay demonstrates strong physical security controls and compliant backup and redundancy infrastructure through AWS, significant gaps exist in governance documentation, technical security controls, and operational security processes. The assessment has identified 1 Critical risk and 4 High risks requiring immediate remediation before any ISO 27001 certification audit could be considered.

Ten information security policies have been formally approved and published, establishing the governance framework required by the ISMS. The immediate priority is remediation of the Critical and High risks — particularly privileged access management, vulnerability scanning, multi-factor authentication enforcement, and incident response planning.

2. Compliance Summary by Control Category

Control Category	Total	Compliant	Non-Comp	Partial	% Compliant
A.5 — Organisational Controls	37	4	15	18	10.8%
A.6 — People Controls	8	4	2	2	50.0%
A.7 — Physical Controls	14	9	1	4	64.3%
A.8 — Technological Controls	34	8	9	17	23.5%
TOTAL — ALL CONTROLS	93	25	27	41	26.9%

3. Key Findings

CRITICAL	A.8 Technological controls is CyroPay's weakest category at 23.5% compliant. Privileged access management (A.8.2), vulnerability scanning (A.8.8), data masking (A.8.11), and DLP (A.8.12) are all non-compliant. These represent the highest risk to payment infrastructure and customer data.
HIGH	A.5 Organisational controls shows 78% of controls only partially compliant. Incident response planning (A.5.24-A.5.28), threat intelligence (A.5.7), and supplier security (A.5.19-A.5.22) are all non-compliant. Governance documentation is the biggest gap and must be addressed before certification.
MEDIUM	A.6 People controls: security awareness training (A.6.3) and security event reporting (A.6.8) are non-compliant. Staff cannot identify or respond to threats even where technical controls are in place. A mandatory awareness training programme must be implemented.
POSITIVE	A.7 Physical controls is the strongest category at 64.3% compliant. The London office has strong physical perimeters, CCTV, and access controls. AWS multi-AZ infrastructure provides compliant backup (A.8.13) and redundancy (A.8.14). These controls require maintenance, not remediation.

4. Priority Risk Remediation Plan

Risk ID	Risk	Score	Rating	Owner	Target
R001	No privileged access management	20	Critical	IT Mgr	30 Jun 26
R007	MFA not enforced across all systems	16	High	IT Mgr	30 Jun 26
R002	No vulnerability scanning or patch SLA	16	High	IT Mgr	31 Jul 26

R005	No formal incident response plan	15	High	CISO	31 Jul 26
R003	No supplier security assessments	15	High	CISO	31 Aug 26
R004	Live data in test environments	15	High	Head Dev	30 Jun 26

5. CISO Recommendation

The Board is requested to note CyroPay's current information security posture and approve the following immediate actions:

- Authorise emergency remediation of R001 (PAM) and R007 (MFA enforcement) within 30 days — these controls have the highest combined risk score and lowest implementation complexity.
- Approve a formal incident response plan development and tabletop exercise before 31 July 2026 to address R005 and meet FCA SYSC 6 obligations.
- Commission a third-party penetration test by Q3 2026 to validate the technical security posture and satisfy ISO 27001 A.8.29 requirements.
- Target ISO/IEC 27001:2022 certification readiness by Q2 2027 following remediation of all Critical and High findings identified in this assessment.